

EU AI ACT PACK

Annex IV Technical Documentation

Working skeleton — Regulation (EU) 2024/1689

Lexy AI Hiring Platform · Generated 2026-07-20

Factual description of the system as built. Not legal advice; assumptions flagged for counsel.

Status: **SKELETON / WORKING DRAFT** — structure per Annex IV of Regulation (EU) 2024/1689.
High-risk classification basis: Annex III §4 (employment, workers management — AI systems intended for recruitment/selection, screening/filtering applications, evaluating candidates).
Compliance deadline for high-risk obligations: 2 August 2026.
Each section lists what Annex IV requires, what already exists in this repo (source of truth links), and what still needs to be authored. Keep this file updated whenever the AI decision surface changes — it is a living regulatory artifact, not a one-off.

Related existing documents:

- docs/AI_SYSTEM_CARD.md — model inventory & intended use
- docs/AI_GOVERNANCE_ARCHITECTURE.md — oversight & decision-enforcement design
- docs/PII_HANDLING.md — data-protection measures
- docs/RUNBOOK_APPEAL_HANDLING.md / docs/RUNBOOK_DATA_DELETION.md — operational procedures
- docs/legal/ai-consent-jurisdiction-memo.md — jurisdictional consent basis

1. General description of the AI system (Annex IV §1)

1(a) Intended purpose, provider, version

- System: **Lexy** — AI-assisted hiring platform (candidate sourcing, resume screening, match scoring, AI interviews, outreach drafting).
- Provider: *[legal entity name, registered address — TO COMPLETE]*
- Version identifiers: model/prompt/scoring/orchestration versions are recorded per decision in `decision_events` (columns `model_id`, `model_version`, `prompt_version`, `scoring_version`, `orchestration_version`).

1(b) Interaction with hardware / other AI systems

- Runs as a web platform; external AI providers: OpenAI (LLM scoring/drafting, Whisper STT), Azure Speech (STT/TTS), Sarvam (Indic STT), ElevenLabs (TTS), HeyGen (avatar video).
- *TO COMPLETE: contractual/DPA references for each provider.*

1(c) Software versions and update policy

- *TO COMPLETE: release cadence, versioning policy, docs/RELEASE_CHECKLIST.md reference.*

1(d) Forms of placing on the market

- SaaS, multi-tenant (agency → client sub-tenant hierarchy).

1(e) Hardware on which it runs

- Cloud-hosted (Replit deployment; external PostgreSQL in production).

1(f) Product photographs / UI

- *TO COMPLETE: screenshots of decision surfaces (pipeline board, decision queue, appeals).*

1(g) Basic description of the user interface for the deployer

- Recruiter dashboard, decision queue (/decision-queue), appeals queue (/appeals), human-review queue (/human-review), transcription health (/admin ops pages).

1(h) Instructions of use for the deployer

- docs/L3xy_Recruiter_User_Guide.md ; candidate-facing disclosures on the interview consent screen and portal.

2. Detailed description of elements and development process (Annex IV §2)

2(a) Methods and steps for development

- *TO COMPLETE: development lifecycle summary; third-party foundation models (OpenAI et al.) are used via API — no in-house training of foundation models.*
- Per-tenant learned scoring: trained via `trainTenantWeights` with sample-size and backtest gates (see memory of design in code: `lib/learned-scoring`).

2(b) Design specifications, architecture

- docs/AI_GOVERNANCE_ARCHITECTURE.md ; scoring flows through fairness wrappers (`FAIRNESS_DIRECTIVE` + `redactPii` around every candidate scorer).

2© Data requirements (datasheets)

- Data sources: recruiter-entered candidate data, resumes, interviews, external sourcing providers (PDL, SERP). *TO COMPLETE: datasheet per data category.*

2(d) Human oversight measures (Art. 14)

- Every AI recommendation requires a named human `final_decision` (`applyHumanDecision`); API tokens cannot attest decisions.
- Mandatory override rationale (≥ 10 chars) on score overrides.
- Oversight-effectiveness monitoring: `GET /governance/oversight-metrics` (deviation rate + rubber-stamp alert, surfaced on the Appeals page).

2(e) Predetermined changes & continuous learning

- Learned scoring weights change only after sample-size + backtest gates; fallback is a static config. *TO COMPLETE: formal change-control description.*

2(f) Validation and testing procedures

- Fairness gate: `test:fairness` (adverse-impact 4/5ths monitoring, demographics firewall).
- STT quality: `test:transcribe`, live alerting, per-language accuracy breakdown (`stt_transcribe_events.language`, Transcription Health page).
- *TO COMPLETE: accuracy metrics summary per release.*

2(g) Cybersecurity measures

- docs/SECURITY_REVIEW_2026-07.md , RLS + application-level tenant sealing, CI route-ownership and Class-B read guards.

3. Monitoring, functioning and control (Annex IV §3)

- Capabilities & limitations: match scores are decision-support only; trust-gated surfaces lead with gate badges; null scores render as “—” (never fabricated).
- Foreseeable unintended outcomes: rubber-stamping (monitored, §2d), per-language STT accuracy skew (monitored), volume bias in readiness score (**known open item**).
- Input data specification: resume, interview transcript, recruiter-entered data; PII redaction before scoring.

4. Appropriateness of performance metrics (Annex IV §4)

- *TO COMPLETE: justification of empty-rate/latency for STT, deviation rate for oversight, adverse-impact ratio for fairness.*

5. Risk management system (Annex IV §5; Art. 9)

- docs/threat_model outputs, fairness mitigation design, kill switch + tenant scoping for AI messaging. *TO COMPLETE: consolidated risk register with owners & review dates.*

6. Lifecycle changes description (Annex IV §6)

- *TO COMPLETE: changelog of relevant system changes (seed from release notes).*

7. Harmonised standards applied (Annex IV §7)

- *TO COMPLETE: list standards (e.g. ISO/IEC 42001) or describe alternative solutions.*

8. EU declaration of conformity (Annex IV §8)

- *TO COMPLETE: copy of the declaration once conformity assessment is done.*

9. Post-market monitoring plan (Annex IV §9; Art. 72)

- In place today: oversight metrics endpoint, STT per-language monitoring & alerts, appeals queue with SLA clocks, erasure queue with GDPR 30-day SLA clocks, append-only `decision_events` retained indefinitely (never pruned); STT event retention 365 days.
- *TO COMPLETE: formal plan document (review cadence, responsible owner, escalation path).*